Evolve Edge MVP Requirements

Modifications

09/03/2026	v1.0	KG/SMP	Original

Contents

Modifications

Contents

Definitions

Scope

- In scope
- Out of scope

Functional requirements

- Common application requirements
- Web app
- Mobile app
- Admin portal
- Back-end

Non-functional requirements

- Milestones
- Platforms
- Location, languages & culture
- Security
- Legal & compliance
- Performance
- Reliability
- Costs

Scalability

Logging & auditing

Analytics & reporting

Content management

Technology

Integrations

Status

Section	Status	Notes
Definitions	Completed	
Scope	Completed	
Functional requirements	In progress	
Web app	In progress	
Admin portal	Not done	
Back-end	Not done	
Non-functional requirements	In progress	
Milestones	Not done	
Platforms	Completed	
Location, languages & culture	Not done	
Security	Not done	
Legal & compliance	Not done	
Performance	Not done	
Reliability	Not done	

Costs	In progress	
Scalability	Not done	
Logging & auditing	Not done	
Analytics & reporting	Not done	
Content management	Not done	
Technology	Not done	
Integrations	Not done	

Definitions

Status: Completed

- Web App - the web application being developed.
- Admin Portal - the web application being developed to administer the system.
- Back-end - the cloud-based services and database being developed.
- Usage - number of users, activity of those users and data stored by those users.
- User types - see User & Organisation Types .

Scope

Status: Completed

High-level descriptions of functional areas that are either in scope or specifically out of scope.

In scope (MVP)

The MVP of Evolve Edge will include the following core capabilities:

- Web App
- Identity & Authentication
    - User registration (email/password)

    - Email verification
    - Login/logout
    - Password reset
    - Optional MFA
- Organization & Multi-Tenant Architecture
- Role-Based Access Control (RBAC)
- Group Hierarchy System
- Simple AI Analysis engine
- Compliance rule engine
- Document ingestion system
- Reporting and alerting system

Out of scope

The following will **not be included in the MVP**:

- Mobile App
- Enterprise SSO (Okta / Azure AD)
- Custom compliance framework builder
- Real-time collaboration
- Advanced workflow automation
- AI training customization
- Multi-organization users
- Advanced analytics dashboards
- Regulatory submission automation
- Chat functionality

Functional requirements

Status: In progress

Web application

Status: In progress

Concepts

- New user creates account with organisation
- Org validation
- 2FA

- Account statuses: open, closed, archived
- Org selects which regulations they adhere to and one or more frameworks within each one.
- Login as user, linked to organisation
- Org docs:
    - An organisation has a set of documents. How these are organised is TBD. It might be that there is one org-wide library and each upload document has to be tied to one or more regulations. It could be that documents are not uploaded but linked to (either individually or folder links). Each document has a well-known types.
    - Formats: PDF, DOCX, TXT etc.
    - When a document is uploaded, it will be processed into a form that is easily consumed later when used in an assessment or an audit.
- Users with appropriate permissions can create/manage workloads
- A workload can be an assessment or an audit
    - Assessment is a workload to check and improve the compliance score of the organisation. Assessment type selection specifies the scope (which can be broad or narrow). Output is maturity evaluation and score, highlights risks and remediation recommendations. When assessment is run, the prompt in the assessment type is used to evaluate and produce outputs.
        - When run, documents in the library pertaining to the assessment type regulation(s) of specific well-known types (TBD) are used as inputs to the assessment.
        - When an assessment is run, the docs associated with the regulation(s)/framework(s) and the docs in the assessment type and certain docs in the organisation library are used along with the assessment type LLM prompt to output certain information and documents.
    - Audit is an evidence based evaluation to determine specific standards/regulations. The goal is to verify and make sure things are in compliance. Structured and formal. Output is pass or fail with findings.
        - Audit is tied to an audit type.
        - When run, documents in the library pertaining to the audit type regulation(s) of specific well-known types (TBD) are used as inputs to the audit.
        - When an audit is run, the docs associated with the regulation(s)/framework(s) and the docs in the audit type and certain

docs in the organisation library are used along with the assessment type LLM prompt to output certain information and documents.

    - Workflows has states: draft, ready to run, running, completed, archive
- Dashboard with compliance overview
    - Overall score
    - Regulation/Framework score (i.e. different regulations)
    - Can upload assessment or audit documents (workload)
    - Risk assessment alert after upload
    - List of generated reports for the assessment/finding
- Admins can manage users (add, edit, delete/archive)
    - Name, email, ID, role(s)
- Users can manage their profiles (depending on permissions)
    - E.g. name, avatar image etc.
- Users(admin) can invite users (PEN testers?) into the workload
- Admin can remove user from workload
- Admin can assign roles
- All users can edit certain things (e.g. avatar)
- Frameworks have a 'weighting' within a regulation (because some are more important than others)
- Account closure
    - Users with 'Close account' permission can close the org account
    - Confirmation will be requested and required
    - Closed accounts can be re-opened by contacting support within a certain period of time (sys setting).
    - Users cannot log into a closed account
    - When an account is closed, all users are logged out
- Feeds
    - Activity feed will be shown in the dashboard page.
    - Items are added to the feed automatically when certain events occur:
        - Document uploads
        - Report generation
        - Compliance score changes
    - Each feed item shown in the feed will display the type, feed text, timestamp, favorite icon.
    - Users can comment on feed items.
    - If a feed item has any comments, the latest comment is shown under the feed item and, if there is more than one comment, the user can expand the feed item to show additional comments.

    - Each comment shows the avatar image of the user that made the comment, the comment timestamp, the comment text, how many likes.
    - Users can reply to comments (so they are hierarchical).
    - Users can like comments.
    - Users can view who liked the comment in a popup by clicking on the number of likes.
    - The feed can be filtered by type, favorited, date rage, text
    - Favoriting/unfavoriting, commenting, liking/unliking a feed item/comment are logged in the audit log.
- Notifications:
    -

Admin portal concepts

- Sys admin can define the regulations and frameworks and the standard documents for each framework (e.g. PCI DSS, HIPAA, SOC2 and future: ISO 27001, NIST)
- Sys admins create and manage assessment types:
    - Has a name
    - Tied to one or more regulations. Each regulation is tied to one or more frameworks. Assessment types contains documents of different types:
        - Types TBD
    - The choice of which document type(s) need to be uploaded for any assessment type lies with the sys administrator.
    - The output of an assessment run with a given type is determined by the output documents defined in that type.
    - Each document pertains to one framework in one regulation in the assessment type.
    - Each assessment type has a LLM prompt that is run when an assessment of that type is executed.
    - Formats: PDF, DOCX, TXT etc.
    - When a document is uploaded, it will be processed into a form that is easily consumed later when used in an assessment.
- Sys admins create and manage audit types
    - Has a name
    - Selection of >=1 regulation(s) and for each regulation, >=1 framework(s)
    - Documents uploaded - each one a specified tp (potentially different to assessment type document types)
        - Types TBD
    - Formats: PDF, DOCX, TXT etc.

    - Has an LLM prompt
    - When a document is uploaded, it will be processed into a form that is easily consumed later when used in an audit.
- System setting
    - Days before closed account deleted/anonymised

Pages

- Landing page
- Sign-up
- Sign-in
- Dashboard
    - Feed for various posts
    - Tiles for compliance status
- Org settings
    - Users
    - Payment/billing
    - Close account
- User profile
- Workloads
- Create/View assessment
- Create/View audit
- Notifications
- Search

Admin portal pages

- Login
- Dashboard
- Workload types
- Create/view workload type
- Settings

See ➕ User Stories Template

- Payment
  - Wallets?
  - Virtual currencies?
  - Deposits and withdrawals?
  - Sales tax (e.g. GST, VAT etc.)?
  - Recurring payments?
  - Re-use of credit card?
  - Invoices (sending, storing, viewing and downloading)?
- Searching:
  - Ability to search for items?

Web Application Requirements

Sign-Up Requirements

Required fields:

- First name
- Last name
- Email
- Password
- Organization name
- Industry type
- Country

Rules:

- Password must meet security standards
- User must accept **Terms of Service**
- Email verification required

Optional:

- Phone number (future)

Social login:

- Google
- Microsoft

Reason: common in enterprise SaaS.

Login Requirements

Supported login methods:

Email + Password

Primary authentication method.

Social Login

- Google
- Microsoft

Multi-Factor Authentication (Optional MVP)

Supported via:

- Authenticator app
- Email OTP

Future:

- SMS OTP

Signed-In Dashboard

Main dashboard shows:

Compliance Overview

- Compliance score
- Framework status

Document Activity

- Documents uploaded
- Analyses completed

Risk Alerts

- High-risk findings
- Compliance gaps

Recent Reports

List of generated reports.

User Management

Status: ?

Users can:

- Reset password
- Change password
- Change email
- Logout
- Update profile

Admins can:

- Invite users
- Remove users
- Assign roles
- Assign groups

User Profile

Status: Not done

Editable fields:

- Name
- Job title
- Department
- Profile image
- Phone number
- Notification preferences

Non-editable:

- Organization
- User ID
- Role (unless admin)

Notifications

Status: Completed

See Notifications

Notification Types

Transactional

- Document analysis completed
- Compliance report ready

Informational

- New compliance framework available
- System updates

Security

- Login alerts
- Suspicious activity

Marketing

- Product updates

Notification Channels

Supported in MVP:

- Email
- In-app notifications

Future:

- Slack
- Microsoft Teams
- SMS

Payment

Status: In progress

Stripe will be used.

Subscription tiers:

Starter - TBD
Professional - TBD
Enterprise - TBD

Billing features:

- Monthly subscriptions
- Credit card storage (within payment provider)
- Invoice generation
- Payment history

Search

Status: Completed

There will be a text search bar and advanced search button in the header accessible from all pages

Users can search:

- Uploaded documents
- Compliance reports
- Risk findings

- Users (admin only)

Search supports:

- Area (e.g. all, docs, reports, findings, users)
- Keyword
- Date
- Regulation/Framework

Search results are shown in a separate page. Search can be refined in that page (e.g. modify the text or the filter)

Solution Specific Requirements

Risk Scoring

Each document receives:

- Compliance score
- Risk severity levels

Severity:

Low
Medium
High
Critical

Compliance Report Generation

Reports include:

- Summary
- Findings
- Risk explanations
- Remediation guidance

Reports downloadable as:

PDF

Admin portal

Status: Not done

Concepts

- Login requirements (which role/permissions allowed, MFA etc.)
- Auto logout?
- What data and configurations can be seen, created, edited and deleted?
- Reports?

Admin users can:

- View all organizations
- Manage system settings
- Monitor usage
- View audit logs
- Manage compliance frameworks

Admin login requires:

- MFA
- Role validation

Auto logout after:

15 minutes inactivity.

Back-end

Status: Not done

- Automatically initiated processes:
  - One each day, all users that have signed up but not verified their email address more than one month ago will be deleted.
  - Once each day, all data for users that closed their account more than one month ago will be anonymised.

Core services:

Authentication Service

Handles:

- login
- tokens
- MFA

Document Processing Service

Handles:

- file uploads
- text extraction

AI Compliance Engine

Processes:

- compliance analysis
- risk scoring

Report Generation Service

Generates:

- compliance reports
- summaries

Automated Processes

Daily tasks:

Unverified User Cleanup

Delete users who:

- signed up
- did not verify email within 30 days

Closed Account Anonymization

Anonymize user data after 30 days.

Non-functional requirements

Status: In progress

Milestones

Status: Not done

See Milestones Template .

Note: All requirements are to be included in the MVP milestone unless stated otherwise.

Platforms

Status: Completed

See Platforms .

Location, languages & culture

Status: Not done

- Locations: All (global)
- Languages: English (US) in MVP. Prepare for multi-language in the future.
- Culture: Based on system settings (dates, times, number formats)
- Currencies: ?
- RTL support: No

Supported locations:

Global

Language:

English (US)

Future:

multi-language.

Currencies:

USD default.

Security

Status: Not done

- Encryption:
  - Data in transit
  - Data at rest (non-public data)
  - Encryption keys managed by cloud services host.
- DDOS:
  - IP blocking
  - Throttling
  - DNS protected
- Secrets management in security policy:
  - Only accessed by authorised people/roles.
  - Stored securely in a reputable secrets manager.
  - Communicated securely between people.
  - Process for rotating documented.
  - No secrets in code repositories (via code or configuration files).
- PEN testing:
  - Full independent PEN test required before handover.
  - All high and medium risk findings to be resolved before handover.

Encryption:

Data in Transit

TLS 1.2+

Data at Rest

AES-256 encryption.

DDoS Protection

Using:

Cloudflare or AWS Shield.

Secrets Management

Secrets stored in:

AWS Secrets Manager

Policies:

- No secrets in code
- Key rotation every 90 days

Penetration Testing

Independent security audit required before production launch.

All high and medium vulnerabilities must be fixed.

Legal & compliance

Status: Not done

- GDPR?
- California Consumer Privacy Act (CCPA)?
- Terms of service?
- Privacy policy?
- Cookie policy & requirements?
- Industry specific? HIPAA? FCA? GC?
- Sovereignty - no specific sovereignty requirements.
- Other?

Required policies:

Terms of Service
Privacy Policy
Cookie Policy

Compliance readiness:

HIPPA

PCI

Future: CCPA, GDPR

Performance

Status: Not done

- Page load times? Time to start responding. Time to complete loading.
- Operation times?
    - <= 3s shows feedback to the user.
    - <= 5s allows operation to continue in the background.
- API response times? 90% < 500ms, 80% < 300ms, 50% < 100ms

Page load target:

< 3 seconds

API response:

50% < 100ms
80% < 300ms
90% < 500ms

AI analysis:

< 30 seconds typical.

Reliability

Status: Not done

- 99% up-time (including for planned maintenance).
- Daily (retained for 7 days) and weekly (retained for 4 weeks) full backups.
- Fully documented and tested full restore procedure.
- Single tenant restore?
- Single user restore?

System uptime target:

99%

Backups:

Daily backups (7 days retention)
Weekly backups (4 weeks retention)

Full restore procedure required.

Costs

Status: In progress

- < $200 per month for up to 1000 users
- < $0.2 per month per user and reducing for over 1000 users.

Target infrastructure cost:

< $200/month for 1000 users.

Recommended architecture:

- Serverless compute
- Managed database
- Cloud storage

Scalability

Status: Not done

- No degradation in performance as usage increases.
- No degradation in up-time as usage increases.
- Reduction in per new user cost as the number of users increases.

Architecture must support:

- horizontal scaling
- increasing documents
- increasing AI workloads

Logging & auditing

Status: Not done

- Detailed logging information must be recorded for troubleshooting purposes. Logs are to be kept for at least 1 week.
- All updates to system settings and user records are to be audited. Audit records are to be kept for a minimum of 2 years.

Logs retained:

minimum 7 days.

Audit records:

minimum 2 years.

Tracked events:

- logins
- user updates
- permission changes
- report generation

Analytics & reporting

Status: Not done

- Analytics information for all page loads and user-initiated operations in the web and mobile apps are to be stored in Google Analytics.
- Analytics of back-end APIs calls and worker initiated operations are to be stored for later analysis and reporting.
- Reports and graphs of user live sign-ups and xxx are to be made available at any time.

User analytics stored in:

Google Analytics.

Backend analytics include:

- API usage
- document analysis metrics

Admin dashboard shows:

- live signups
- active users
- reports generated

Content management

Status: Not done

- Most assets are static and fixed so can be served by the web server.
- Assets of type [DYNAMIC ASSETS TYPES] are dynamic and must be configurable without requiring a redeployment by content management users at any time.
- The tool used to configure dynamic assets can be off-the-shelf if this is possible as the asset data can be stored anywhere.
- The cost of storing and serving assets must not exceed $100 per month. This cost is not included in the general costs in the Costs section above.

Static assets:

served via CDN.

Dynamic assets:

- compliance templates
- framework definitions
- policy templates

Stored in CMS.

Technology

Status: Not done

Recommended MVP stack (not mandatory):

Frontend: Next.js

Backend: FastAPI

Database: PostgreSQL

AI: OpenAI API

Infrastructure: AWS

Integrations

Status: Not done

- Stripe must be used as the payment provider.
- The address lookup provider can be any that supports global address lookup by country and postal code.

Stripe

Subscription billing.

Address lookup:

Global provider such as:

- Google Places
- Loqate